

Unpatched CVE · 147 Million SSNs Stolen · 76 Days Silent · \$575M Settlement

 **THIS PROJECT:** Understand what happened, map the attack, research the CVE. This project ends with a CVE Research Worksheet (50 points).

 **CVE / ADVISORY:** CVE-2017-5638 (Apache Struts 2 RCE, CVSS 10.0 CRITICAL) — nvd.nist.gov/vuln/detail/CVE-2017-5638

INCIDENT OVERVIEW

From May 13 to July 30, 2017, attackers exploited CVE-2017-5638, a known, publicly patched vulnerability in Apache Struts web framework, to breach Equifax — one of the three largest credit reporting agencies in the United States. The patch had been available for 69 days before Equifax was compromised. Over 76 days, attackers ran ~9,000 queries against 48 different Equifax databases, exfiltrating 147 million Social Security numbers, birthdates, addresses, and driver's license numbers. An expired SSL certificate on Equifax's traffic inspection tool meant malicious traffic went uninspected for 19 months. Settlement: \$575 million.

KEY FACTS AT A GLANCE

- CVE-2017-5638 patch was available 69 days before Equifax was breached — this was 100% preventable
- 147.9 million Social Security Numbers exposed — nearly half the U.S. adult population
- Also stolen: birth dates, addresses, driver's license numbers, 209,000 credit card numbers
- ~9,000 database queries run during the 76-day breach against 48 different databases
- Expired SSL inspection certificate — encrypted malicious traffic went uninspected for 19 months
- \$575M FTC settlement — largest data breach settlement in history at the time
- CEO Richard Smith resigned September 2017; three executives investigated for insider trading

🎯 **OBJECTIVE:** Students understand the Equifax Data Breach at a high level and apply the CIA Triad to identify which pillars were violated and how.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:15	Welcome & Project Overview	Distribute Project 7 packet. Explain: this project is about understanding exactly what happened. Next project we apply frameworks and write the executive summary.
0:15-0:45	Lecture: CIA Triad	Teach Confidentiality, Integrity, Availability. Use real-world examples. Ask: what happens when each one fails?
0:45-1:10	Read the Incident	Students read the Incident Overview (15 min silent). Then open discussion: What happened? What was your first reaction?
1:10-1:50	CIA Triad Mapping Activity	Students fill out their CIA Triad worksheet — which pillars were violated, specific evidence, impact rating (Low/Med/High/Critical).
1:50-2:00	Debrief & Homework	Share out. Homework: Write a 1-paragraph plain-English explanation of the incident for a non-technical reader.

🎯 **OBJECTIVE:** Students map the complete attack through all 7 Kill Chain phases using specific incident evidence.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:30	Lecture: Kill Chain	Teach the 7 phases. For each: what does the attacker do? At what point could a defender have stopped this?
0:30-1:00	Demo: Phase Walkthrough	Walk through ONE Kill Chain phase together as a class. Model your analysis process out loud.
1:00-1:45	Kill Chain Mapping	Students complete the full Kill Chain table — all 7 phases with specific incident evidence, not generic descriptions.
1:45-2:00	Discussion	Which phase was the most preventable? Which phase was most surprising? What would have stopped the attack?

🔗 **OBJECTIVE:** Students identify specific ATT&CK techniques, navigate attack.mitre.org, and explain each technique in plain English.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:30	Lecture: MITRE ATT&CK	Explain Tactics (the WHY), Techniques (the HOW), Procedures (the specific implementation). Show the ATT&CK Navigator.
0:30-0:50	Live Demo: attack.mitre.org	Navigate the matrix together. Look up ONE technique from this incident. Show the description, procedure examples, and detection methods.
0:50-1:40	ATT&CK Research Lab	Students identify 3-5 techniques from the incident. For each: ID, name, tactic, and plain-English explanation.
1:40-2:00	Class ATT&CK Heat Map	Build a shared map on the board. Students add techniques. What does the pattern tell us about where to focus defenses?

 **OBJECTIVE:** Students research the CVE or CISA advisory, build the incident timeline, finalize and submit the CVE Research Worksheet.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:20	CVE Orientation	Walk students through nvd.nist.gov and cisa.gov . Show them how to read a CVE entry: description, CVSS score, references.
0:20-1:10	Research Lab + Worksheet	Students research: CVE-2017-5638 (CVSS 10.0), Apache S2-045 bulletin, CISA Known Exploited Vulnerabilities Catalog. Document: patch/fix, when available, how the incident was contained, who was involved.
1:10-1:40	Timeline + Finalization	
1:40-2:00	Submit + Next Project Preview	Students submit completed CVE Research Worksheet (50 points). Open discussion: What surprised you? Preview next project: NIST CSF, attacker methodology, and Executive Summary.

KILL CHAIN REFERENCE — FULL ANALYSIS

PHASE	WHAT HAPPENED IN THIS INCIDENT	DEFENDER OPPORTUNITY
1. Reconnaissance	Scanned internet-facing Equifax web apps for Apache Struts version; CVE-2017-5638 was public knowledge	Threat intelligence; dark web monitoring; monitor vendor relationships
2. Weaponization	Used the publicly available proof-of-concept exploit for CVE-2017-5638 — no custom malware needed	Patch management; secure development practices; code signing
3. Delivery	Sent specially crafted HTTP Content-Type header to Equifax's online dispute portal running vulnerable Struts	Email filtering; MFA; user security awareness training
4. Exploitation	Malformed Content-Type header triggered remote code execution on Equifax's web server	Patch known CVEs; WAF; regular penetration testing
5. Installation	Deployed web shells for persistent access; expired SSL cert meant traffic was not inspected	File integrity monitoring; application whitelisting; EDR
6. Command & Control	Used encrypted HTTPS traffic; expired SSL cert on IDS prevented inspection for 19 months	DNS filtering; SSL inspection; anomaly detection on outbound traffic
7. Actions on Obj.	Ran ~9,000 queries against 48 databases over 76 days; exfiltrated in small batches to avoid volume alerts	Data loss prevention (DLP); database activity monitoring; network segmentation

MITRE ATT&CK TECHNIQUE REFERENCE

TECHNIQUE ID	TECHNIQUE NAME	HOW IT WAS USED
T1190	Exploit Public-Facing Application	Exploited CVE-2017-5638 in Apache Struts on Equifax's internet-facing dispute portal
T1059	Command and Scripting Interpreter	Used web shells for post-exploitation command execution on compromised servers
T1005	Data from Local System	Queried 48 databases (~9,000 queries) to collect and stage PII for exfiltration
T1048	Exfiltration Over Alternative Protocol	Exfiltrated data in encrypted form; expired SSL cert allowed this to go uninspected
T1046	Network Service Scanning	Mapped Equifax's internal network after initial compromise to find 48 database systems

CVE / ADVISORY REFERENCE

 **IDENTIFIER:** CVE-2017-5638 (Apache Struts 2 RCE, CVSS 10.0 CRITICAL) — nvd.nist.gov/vuln/detail/CVE-2017-5638

HOW IT WAS PATCHED

- Apache Software Foundation released patch on March 7, 2017 in versions 2.3.32 and 2.5.10.1 (S2-045)
- Fix: properly validate and sanitize the Content-Type HTTP header before passing to the Jakarta multipart parser
- Equifax finally patched AFTER breach discovered on July 29, 2017 — 144 days after patch was released
- Equifax rebuilt compromised application servers identified in forensic investigation
- Expired SSL inspection certificate renewed and certificate lifecycle management process overhauled

HOW THE INCIDENT WAS CONTAINED

- Equifax discovered breach July 29, 2017 — took vulnerable dispute portal offline immediately
- Hired Mandiant for forensic investigation; traced full 76-day attack timeline
- Notified FBI, FTC, and state attorneys general within days of discovery
- Public notification: September 7, 2017 — 40 days after internal discovery
- Offered 1 year of free credit monitoring to all 147 million affected consumers

INCIDENT TIMELINE

DATE	EVENT
Mar 7, 2017	Apache releases CVE-2017-5638 patch — Equifax DOES NOT apply it
Mar 8, 2017	CISA/US-CERT issues active exploitation alert for CVE-2017-5638
Mar 15, 2017	Equifax runs internal scan for vulnerable Struts — MISSES internet-facing portal
May 13, 2017	Attackers begin exploiting CVE-2017-5638 against Equifax (69 days after patch)
May 13–Jul 30	76-day active exfiltration — ~9,000 queries, 147M records stolen
Jul 29, 2017	Equifax security team discovers anomalous traffic
Sep 7, 2017	Public disclosure — 40 days after internal discovery
Sep 26, 2017	CEO Richard Smith resigns
Jul 22, 2019	FTC announces \$575M settlement

PROJECT 7 ASSESSMENT — CVE RESEARCH WORKSHEET (50 POINTS)

 **DUE:** Thursday of this project. Submit to your instructor.

[10 pts] What is the CVE number and CVSS score for this incident? If no CVE exists, what CISA advisory or identifier applies? What does the CVSS score (or the absence of a CVE) tell you about the nature of this vulnerability?

[10 pts] Describe the vulnerability or weakness in your own words — plain English, no jargon. A non-technical reader should completely understand what went wrong.

[10 pts] When was the official patch or fix released? How much time passed between the fix being available and the breach occurring? What does that timeline tell you about the organization's security practices?

[10 pts] Who was involved in containing this incident? What specific actions were taken? How long did full containment take?

[10 pts] List your 3 most critical "From Here On Out" recommendations for any organization that uses similar technology. For each, explain specifically WHY it would have prevented or reduced this breach.

REFERENCES & RESOURCES

- nvd.nist.gov/vuln/detail/CVE-2017-5638 — full technical details, CVSS score, references
- U.S. House of Representatives Report: "The Equifax Data Breach" (December 2018) — oversight.house.gov
- FTC: "Equifax to Pay \$575 Million" — ftc.gov (July 22, 2019)
- Apache Security Bulletin S2-045 — struts.apache.org/security/security-bulletins
- CISA Known Exploited Vulnerabilities Catalog: cisa.gov/known-exploited-vulnerabilities-catalog
- MITRE ATT&CK: attack.mitre.org — search T1190, T1059, T1048